

Preston-Check — Customer Portal, Admin Portal, and KPI Catalog

Design doc for the SaaS surfaces that wrap the open scanner

Preston-Check Maintainers

2026-05-04

Customer Portal, Admin Portal, and KPI Catalog

The open scanner is the funnel. The portals are where the money is made and the operator sees the business. This document specs both surfaces and the metric system that ties them together.

Architecture overview

There are two portals and three backend services:

The **Customer Portal** at `app.preston-check.com` is what paying customers use. It is a multi-tenant Next.js app that consumes scanner output (markdown + JSON) posted from CI or uploaded manually. It renders dashboards, evidence bundles, branded PDFs, and history; it does not run the scanner itself.

The **Admin Portal** at `admin.preston-check.com` is what the operator (you) uses to run the business. Customer accounts, license issuance, sales pipeline, revenue, support tickets, threat-intel triage, system health. Same Next.js app shell as the Customer Portal but a different role + side-nav.

The **API** at `api.preston-check.com` is the shared Cloudflare Worker backend. It speaks to D1 (Postgres-compatible relational data) and KV (aggregations + cache), authenticates customer requests with a JWT, and gates admin requests behind hardware-token-bound sessions.

The **Telemetry collector** at `telemetry.preston-check.com` is the existing Cloudflare Worker in `workers/telemetry/`. It is the only public ingest endpoint and feeds the data moat.

The **Stripe integration** handles billing webhooks via the API. Stripe holds the source of truth for subscriptions, invoices, refunds; the API mirrors enough state to render the customer's billing page and the operator's revenue dashboard without round-tripping to Stripe on every request.

Customer Portal

Five primary surfaces, each a single screen. Aggressive simplicity is the goal — security-tool dashboards over-stuff and lose people.

1. Home (the score view)

Above the fold: a single grade letter (A–F) and the numeric score. Below it, three callouts: top critical findings, scan history sparkline, peer percentile (when available). Right rail: which framework controls are covered vs. failing. This is the ten-second view a CTO or CISO opens once a week to know whether things are okay.

2. Repos

A table of every repo the customer has connected. Columns: name, language, last scan timestamp, score, score-30d-trend, blocking-finding count. Click any row to drill into the repo's latest report. Connect-new-repo flow uses a CI install token rather than OAuth — fewer permissions, less surface area.

3. Findings

Per-finding view across the entire org. Filter by severity, framework, file pattern, age. Each finding shows file:line:content, the AI assessment (when AI augmentation is enabled), the suggested patch (when auto-fix is enabled), the originating check ID with its OWASP / framework citations, and real-world incident references. "Mark as accepted risk" with reason required. "Mark as false positive" with reason required and feedback flows back into the AI training pipeline.

4. Compliance

Framework-control rollups. Pick a framework (PCI-DSS v4, SOC 2, MiCA, etc.) and see every control with the checks that map to it, the latest pass/fail status across all repos, and a "generate evidence bundle" button. Output is a PDF + a ZIP of the underlying scanner reports cross-linked to the control catalog. This is the deliverable a customer hands to their auditor.

5. Settings

Sub-pages for: organization (name, logo for Pro/Enterprise white-label), team members (invite by email, roles: Owner / Admin / Auditor / Member), billing (Stripe-hosted subscription, plan upgrade/downgrade, invoices, seats), license keys (regenerate, revoke), API tokens (one-time-shown, scoped to a single repo or all), notifications (Slack webhook, email digest, threshold alerts), and data export (download every scan ever).

Admin Portal

The operator's daily driver. Side-nav: Customers, Sales, Revenue, Users, Licenses, Threat-Intel, Support, System.

Customers

The master list. One row per organization. Columns: name, plan, seats, MRR, signup date, last-scan date, churn-risk score, account owner. Click through to the customer detail view: every user under that org, every repo, every license issued, billing history, support tickets, audit log of admin actions taken on the account. "Impersonate" button (logged, time-limited, read-only) for support cases — never used for sales or marketing without explicit consent.

Sales

A simple pipeline kanban: Lead → Qualified → Demo → Trial → Closed-won / Closed-lost. Each card pulls from inbound channels: free-tier signups flagged by usage, GitHub Action installations, Slack-channel mentions, inbound email. Click to add notes, schedule follow-ups, attach documents, move stages. Forecast view: weighted pipeline by stage probability × ACV. Win-rate chart by source channel.

Revenue

The CFO view. Top of page: MRR, ARR, runway, gross margin, net retention, quick-ratio. Below: monthly cohort retention heatmap, revenue waterfall (new + expansion + reactivation - churn - contraction). Sub-pages: per-customer billing history, refunds, dunning queue, dispute resolution. Stripe is source of truth; this surface mirrors for fast queries and offline drill-down.

Users

Every individual user across every customer. Filter by org, role, last login. Suspend, reset password (sends magic link), unlock. Bulk actions for cleanup. Audit log of every user-affecting admin action.

Licenses

License issuance dashboard. Currently this happens via `tools/issue-license.sh` from the operator's terminal — the Admin Portal should provide a UI wrapper that enforces the same Ed25519 signing and emits the PEM-style envelope. Columns: customer, tier, issued, expires, status (active / expired / revoked). One-click revoke; one-click reissue with new expiry. The signing key never leaves the operator's machine — the portal's issuance UI either calls a local helper via a hardware-key-authenticated push, or staff initiate from a HSM-backed signing server. (See "What lives where" below.)

Threat-intel

Triage queue for the weekly cron. Each row is a draft check that landed in `checks/community/proposed/` from the NIST NVD ingest. Columns: CVE ID, fintech-relevance score, languages affected, draft check link, status (pending / accepted / rejected / promoted). Click to author the grep pattern in a Monaco-style editor with live regex-tester against a fixture corpus, then promote to `checks/community/accepted/` with one button. This is what makes the catalog grow weekly without consuming the maintainer's flow time.

Support

Inbox of customer tickets. Email → ticket. Slack thread → ticket via slash command. Each ticket has SLA timer, priority, status, assigned owner, AI draft response (gated, never auto-sent). Sub-pages: SLA dashboard (response time per priority), customer-effort score (CSAT + 1-5 scale), backlog by age. The metric to optimize is "time from ticket creation to first human-authored response" — that is what predicts NPS and retention better than resolution time.

System

Operational health. Telemetry endpoint p95 latency. D1 / KV size. GitHub Actions usage rate (stale runs flagged). Docker Hub pulls/day. Homebrew tap install rate. Threat-intel cron last-success timestamp. Background-job queue depth. The single most useful thing on this page is the **build attestation panel** showing the SHA-256 of the latest published scanner release tarball, when it was published, and which signing key authored it — this is what the operator points an auditor at to demonstrate supply-chain hygiene.

What lives where (security boundaries)

The operator's signing keypair — the most sensitive secret in the entire system — never lives in any portal or database. It stays on a single hardware-bound machine (operator laptop with FileVault + Touch ID, or an HSM). License issuance from the Admin Portal triggers a hardware-prompt-authenticated signature; if the operator is not at the machine, no licenses can be issued. This is the

right tradeoff: license issuance is a low- frequency event (handful per week at peak), and the alternative — hot signing keys in a cloud HSM — broadens the blast radius if the cloud account is compromised.

PII (customer emails, names, payment methods) lives in D1 with row-level encryption on the email column. Stripe holds payment method tokens; the portal never sees PAN or CVV. JWT signing key for the customer portal is distinct from the Ed25519 license-issuance key.

The Admin Portal sits behind a separate Cloudflare Access policy. Two named operators with hardware tokens. Every admin action is logged with the acting operator, the timestamp, and the targeted resource — and the log is append-only.

KPI Catalog

KPIs are organized in five tiers. The North-Star tier is what you check weekly. The other tiers feed into it.

North Star

The four metrics that define whether the business is working.

- **MRR** — monthly recurring revenue. Ground truth: Stripe.
- **ARR** — $\text{MRR} \times 12$, plus annual-prepaid contracts at full annualized value. The number the board sees.
- **Net Revenue Retention (NRR)** — $(\text{starting MRR} + \text{expansion} + \text{reactivation} - \text{contraction} - \text{churn}) / \text{starting MRR}$, on a trailing-12-month basis. Above 110% is healthy; above 130% is exceptional.
- **Gross margin** — $(\text{revenue} - \text{cost of revenue}) / \text{revenue}$. For a SaaS layered on an open scanner, this should be $\geq 75\%$ by year 2.

Adoption funnel

How the open scanner converts to a paid customer.

- **Weekly active scanners** — distinct repo hashes that emit telemetry per week. Telemetry is opt-in; assume 30–40% opt-in rate at scale, so weekly scans are 2.5–3.3× the telemetry count.
- **Brew installs** — Homebrew analytics. Daily and 30-day.
- **Docker pulls** — Docker Hub analytics for `ghcr.io/preston-check/scan`.
- **GitHub Action invocations** — `preston-check/scan-action` usage stats.
- **GitHub stars** — vanity but correlated; track the 30-day delta.

- **Free → Pro conversion rate** — (new Pro signups in period) / (free- tier active scanners 90 days prior). Snyk's published rate is around 2%; early targets should be 0.5–1% with a steady climb.
- **Time-to-first-scan** — install timestamp to first scan timestamp, p50. Indicates onboarding friction.
- **Time-to-first-paid-conversion** — first scan to first paid invoice, p50, only over converted accounts.

Product quality

The features that drive retention.

- **AI false-positive rate** — (findings marked false-positive by users) / (total AI-classified findings). Lower is better.
- **AI auto-fix acceptance rate** — (patches applied) / (patches generated). Snyk's number is around 35%; we should beat that on fintech-narrow contexts.
- **Mean check runtime** — p50 and p99 across the catalog. If p99 climbs above 200 ms, audit the catalog.
- **Findings density** — average critical+high findings per repo at first scan. Trends down across the customer base over time means our customers are getting better — and that is the story for the State of Fintech Security report.

Moat health

The metrics that grow the assets competitors cannot copy.

- **Telemetry volume** — scans/week emitting opt-in telemetry. The data moat compounds with this number.
- **Threat-intel drafts merged/week** — promoted from `checks/community/proposed/` to `checks/community/accepted/`. This is the “catalog updates faster than humans can write” indicator.
- **Catalog growth rate** — net new checks per quarter. Caveat: not all growth is good, quality > count past 300.
- **Peer-comparison data points per segment** — telemetry counts grouped by industry × scale × geography. Below ~50 per cell, percentiles are noisy; above ~200, they're crisp.
- **Auditor partnerships signed** — count of mid-tier and Big Four firms that accept Preston-Check evidence packets. The single best leading indicator of “Required” stage transition.
- **Compliance-platform integrations live** — Drata, Vanta, Secureframe, Tugboat. Each is a 10x leverage channel.

Customer success

The metrics that prevent churn.

- **Weekly active customers (WAC)** — distinct paid orgs that ran at least one scan in the past 7 days.
- **Scans per customer per week (SCPW)** — average across paid customers. Below 1 means they are not integrated into CI; above 5 means they're using the tool in their actual flow.
- **Churn rate** — (orgs that didn't renew) / (orgs eligible to renew), monthly. Single best leading indicator of product-market-fit problems.
- **Expansion revenue rate** — (revenue from existing customers added in period) / (starting revenue from those customers). Healthy SaaS: $\geq 0.5\%$ per month.
- **NPS** — collected via in-app survey at 30, 90, and 365 days.
- **Time to first response (TTFR)** on support tickets — strongest single predictor of NPS at 90 days.

Reporting cadence

- **Weekly:** North-Star + adoption funnel + churn. 30-min Monday review.
- **Monthly:** full KPI roll-up shared with the team. Cohort retention. Per-channel acquisition cost vs. LTV.
- **Quarterly:** revenue + moat-health deep dive. Customer cohort analysis. Competitor scan (open-source competitor catalogs, what they've shipped, what we've shipped).
- **Annually:** State of Fintech Security report (data dump from telemetry). Yearly board deck.

Build sequence

The portal work has its own roadmap. Cheapest highest-leverage moves first. Two-developer-quarter assumptions throughout.

Q3 2026 — Customer Portal v1 (MVP). Repos list, latest scan view, Stripe billing integration, manual scan upload. Auth via magic link. Branded PDF generation. Goal: first paying Pro customer.

Q4 2026 — Admin Portal v1. Customer list, license issuance UI, revenue dashboard mirroring Stripe, support ticket inbox. Goal: operator runs the entire business from the portal without shell access.

Q1 2027 — Compliance v2 + multi-repo aggregation. Framework-control rollups, evidence-bundle generation, multi-repo trends, peer percentiles (once telemetry has volume). Goal: first Enterprise contract.

Q2 2027 — Threat-intel triage UI + AI feedback loop. Move `checks/community/proposed/` review into the Admin Portal with regex tester. Capture user "false-positive" / "fix accepted" signals into the training set for the AI layer. Goal: AI quality measurably improves quarter over quarter.

Q3 2027 — SSO + advanced enterprise. SAML / OIDC, audit logs, on-premise deploy option for high-regulation customers. Goal: 5+ Enterprise customers running mission-critical compliance through the portal.

The portal is the monetization layer. The scanner stays free, growing, and viral; the portal is the proprietary surface that converts adoption into recurring revenue. Build sequence is therefore “money-first”: billing + multi-repo before any feature that doesn’t directly affect revenue or churn.